

08 — Incident Response

NIST phases, seven layers, and evidence-first practice

Educational / Defensive DFIR Study Notes

LEARNING OBJECTIVES

- Recite NIST IR phases and explain why containment comes early
- Apply the seven response layers without mixing cause and damage
- Order evidence collection by volatility and preserve chain of custody
- Take correct account and network actions under pressure

SCOPE REMINDER

- This material covers detection, artifacts, and incident response only.
- Attacker actions are phrased as 'adversaries may...' then pivot to evidence.
- Tool/command names appear as IOC strings / exam knowledge — not how-to guides.

NIST IR phases

Phase	Goal	Example activities
1. Preparation	Be ready before incidents	Playbooks, logging, contacts, golden images, retainers
2. Detection & Analysis	Know it is real and scoped	Alert triage, IOC validation, timeline, impact estimate
3. Containment	Stop the bleeding	Isolate hosts, block IOC, disable accounts, network ACLs
4. Eradication	Remove cause	Delete persistence, rebuild, patch exploited vuln
5. Recovery	Restore safely	Restore from clean backups, monitor, staged reconnect
6. Lessons Learned	Improve	Postmortem, detection gaps, training, control upgrades

CONTAIN FIRST

- Once you understand enough to act without destroying critical evidence needlessly, contain.
- Do not wait for perfect root-cause analysis while adversaries still have access.
- Balance: quick containment vs preserving volatile memory — plan both in the playbook.

Seven layers of response

Layer	Actions
Network	Isolate VLAN/host; block IOC IPs/domains; sinkhole; disable VPN routes as needed
Endpoint	Collect (memory/logs/disk triage); analyze; remove persistence; reimage if required
User	Communicate phish context; password resets; awareness; verify unusual user actions
Application	Disable abused apps/features; rotate app secrets; patch; take web app offline if shelled
Account	Disable compromised accounts; reset creds; revoke sessions/tickets; review privileges
Evidence	Memory → logs → disk; hash; chain of custody; legal hold
Recovery	Restore services; heightened monitoring; validate clean before trust

Cause vs damage

Keep two questions separate: **How did they get in / stay in?** (cause — vulnerability, phish, persistence) versus **What did they touch or steal?** (damage — data, systems, fraud). Eradication targets cause; business reporting needs damage. Mixing them muddies priorities.

Evidence order & custody

- **Memory first** (when relevant) — injection, fileless, credentials, encryption keys
- Then **logs** (volatile rotating buffers, remote SIEM copies)
- Then **disk** (full image or targeted KAPE/triage)
- Document: who collected, when, tool/version, hashes, storage location, transfers
- Chain of custody forms for evidence that may enter legal proceedings

Account response checklist

- Disable or lock clearly compromised accounts
- Reset passwords / rotate keys; revoke Kerberos tickets and refresh tokens
- Review group membership and privileged roles (especially Domain Admins)
- Inspect authentication logs (4624/4625, Azure/M365 sign-in) for parallel sessions
- Watch for adversary recreation of accounts or new API tokens

How do I prove the incident is contained?

- No further C2 from fleet hunts (Velociraptor / EDR) after blocks
- Persistence inventories clean on previously affected hosts
- Compromised accounts show no new authentications; resets completed
- Monitoring rules fire on residual IOC tests (and you verify they work)
- Business services restored from known-good sources with elevated watch

Common exam traps

- Skipping containment until full malware RE is done
- Reimaging before memory capture when fileless activity is likely
- Resetting passwords without revoking existing tickets/sessions
- Focusing only on the patient-zero host and missing lateral movement
- Declaring recovery complete without lessons-learned / detection improvements

QUICK REFERENCE

- NIST: Prep → Detect/Analyze → Contain → Eradicate → Recover → Lessons
- Contain first (when safely possible)
- 7 layers: network, endpoint, user, app, account, evidence, recovery
- Evidence: memory → logs → disk + chain of custody
- Separate cause from damage; rotate creds AND revoke sessions

Mini Self-Check

Answer these without looking back. Answers are on the next page.

- Q1.** List the six NIST IR phases in order.
- Q2.** Which phase should generally begin as soon as you can act safely?
- Q3.** Name the seven response layers.
- Q4.** What is the preferred evidence collection order by volatility?
- Q5.** Besides resetting a password, what account action is often required after Kerberos exposure?

Self-Check Answers

A1. Preparation; Detection & Analysis; Containment; Eradication; Recovery; Lessons Learned.

A2. Containment.

A3. Network, endpoint, user, application, account, evidence, recovery.

A4. Memory → logs → disk (then maintain chain of custody).

A5. Revoke tickets/sessions (and review privileges / auth logs); disable the account if appropriate.